Universidad Nacional de Ingeniería

Área de Conocimiento de Tecnología de la Información y Comunicación

ASIGNATURA: AUDITORIA DE SISTEMAS

Líder en Ciencia y Tecnología

Marzo-Abril 2026

Carrera:

Ingeniería de Sistemas

Programa de asignatura/componente

MARCO METODOGOLICO PARA EL DESARROLLO DE AUDITORIA DE SISTEMAS

Clase practica

Elaborado por: Gerson Antonio Valdivia 2013-61725
Haxell Trejos Rodriguez 2011-39659
Stephanie Lucia Mora Chavez 2018-0261S
Alisson Michell Navarro Goussén 2016-0470U
Arleth del Rosario Velásquez Gómez 2019-3036S

Fecha de elaboración:

11/04/2026

CLASE PRACTICA NO.1

Objetivo: Aplicar los conocimientos adquiridos durante el desarrollo de los temas relacionados con el marco metodológico para el desarrollo de las auditorias.

Descripción: Según sus equipos de trabajo de máximo 5 estudiantes, deben revisar la documentación y planteamientos de esta actividad. En este caso deben seguir las instrucciones, de tal forma que se logre realizar un trabajo coordinado y se resuelva de manera efectiva la problemática planteada.

Aspectos de interés: El marco metodológico se compone de varios elementos clave:

Objetivo de la Auditoría: Determinar el nivel de seguridad, cumplimiento normativo y eficiencia de los sistemas.

Alcance de la Auditoría: Definir qué sistemas, procesos, redes, aplicaciones y datos serán evaluados.

Normativas y Estándares: Utilización de marcos o metodologías como:

- **ISO 27001/27002** (Seguridad de la Información)
- **COBIT** (Gobierno y control de TI)
- **ITIL** (Gestión de Servicios TI)
- **NIST** (Guías de seguridad informática)
- **COSO** (Control interno y gestión de riesgos)
- **ISACA**

Existen diversas metodologías utilizadas en auditoría informática, dependiendo del enfoque y del objetivo de la auditoría. Algunas de las más comunes son:

Metodología COBIT (Control Objectives for Information and Related Technologies)

- Proporciona un marco de gobierno y gestión de TI.
- Se basa en la evaluación de procesos de TI en cinco dominios clave: Planificación y Organización, Adquisición e Implementación, Entrega y Soporte, Monitoreo y Evaluación, y Gobierno de TI.

Metodología ISO 27001/27002

- Se centra en la gestión de seguridad de la información.
- Evalúa controles en áreas como acceso, cifrado, gestión de incidentes, continuidad del negocio, etc.

⬭ Metodología NIST (National Institute of Standards and Technology)

- Ofrece guías para auditorías de seguridad cibernética.
- Se utiliza en cumplimiento con normativas como NIST 800-53 (Controles de Seguridad y Privacidad).

⬭ Metodología ITIL (Information Technology Infrastructure Library)

- Evalúa la gestión de servicios de TI.
- Se enfoca en la eficiencia y calidad del servicio TI en la organización.

⬭ Metodología de Pruebas de Penetración (Pentesting)

- Utiliza herramientas como Kali Linux, Metasploit, Nmap, etc.
- Se basa en metodologías como **OWASP** (para seguridad en aplicaciones web) o **PTES** (Penetration Testing Execution Standard).

⬭ Metodología de Análisis Forense Digital

- Se aplica cuando se investiga un incidente de seguridad.
- Usa herramientas como Autopsy, EnCase, FTK para recuperar y analizar evidencia digital.

Continuando con el orden de ideas anteriores, realice una investigación a profundidad sobre las metodologías para realizar auditoria y los tipos de auditorías, y posteriormente realice lo siguiente:

ASIGNACION 1: Investigue sobre los diferentes tipos de auditorías relacionadas con la informática, TI o Sistemas Informáticos. Posteriormente realice las siguientes actividades. pts

1. Cual es el procedimiento, tareas y aspectos a evaluar en la auditoria de sistemas de información

- **Procedimiento:** Normalmente de divide en tres pasos. Primero la Planeación (donde conocemos qué sistemas usa la empresa y cómo funciona el negocio), luego la Ejecución (hacer entrevistas, revisar documentos y hacer pruebas de campo) y finalmente el informe (donde presentamos los hallazgos y recomendaciones).

- **Tareas principales:** Revisar los manuales de usuario y técnicos, entrevistar al personal del área de sistemas, revisar los contratos con proveedores de software y comprobar que haya respaldos diarios.

- **Aspectos a evaluar:** Se revisa la eficiencia del hardware y software, cómo se gestiona el desarrollo de nuevos programas ciclos de vida software, el mantenimiento de las bases de datos y si el departamento de TI está cumpliendo con los objetivos de la gerencia.

2. Cuál es el procedimiento, tareas y aspectos a evaluar en la auditoria de seguridad

- **Procedimiento:** Aquí el enfoque es el riesgo. Empieza con la Identificación de activos (saber qué hay que proteger), luego la Evaluación de vulnerabilidades (buscar huecos de seguridad), las Pruebas de control (Ver si los firewalls o antivirus funcionan) y el Reporte de incidentes o riegos.

- **Tares principales:** Escaneo de puertos en los servidores, pruebas de penetración básicas (pestesting), revisión de la configuración de firewall, y comprobación de las políticas de contraseñas.

- **Aspectos a evaluar:** Aquí se evalúa la famosa traída de la seguridad: Confidencialidad, integridad y Disponibilidad. También se revisa la seguridad física (quién entra el cuarto de servidores) y lógica quién tiene permisos de administrador en la red.

3. Construya un formato de instrumento de recopilación de información, relacionado con auditoria de seguridad.

ID	Criterio de Seguridad a Evaluar	Sí	No	Observaciones / Evidencia
SEG-01	¿Se exige el cambio obligatorio de contraseñas cada 90 días?			
SEG-02	¿Están bloqueados los puertos USB en las computadoras de los usuarios comunes?			
SEG-03	¿Existe un Firewall perimetral configurado para bloquear tráfico no autorizado?			
SEG-04	¿El cuarto de servidores cuenta con control de acceso biométrico o llave electrónica?			
SEG-05	¿Se utiliza autenticación de dos factores (MFA) para conexiones remotas (VPN)?			

4. Prepare un ejemplo o caso donde se aplique de manera general cualquiera de estas auditorias.

Ejemplo o Caso Práctico (Auditoría de Cumplimiento + Seguridad)

"FarmaSalud S.A.", una empresa farmacéutica que maneja datos sensibles de pacientes (regulados por GDPR/LOPDGDD), contrata una Auditoría de Cumplimiento y Seguridad para su nuevo sistema de gestión de ensayos clínicos.

Objetivo: Verificar el cumplimiento normativo y la seguridad lógica del sistema.

Procedimiento Aplicado:

1. **Planificación**: El auditor define el alcance: Base de datos de pacientes (SQL Server), aplicación web de gestión y servidor de backups.
2. **Revisión de Controles**: Se solicita la política de privacidad y el registro de actividades (logs). Se detecta que los logs no registran quién consultó el historial de un paciente específico (falta de trazabilidad).
3. **Pruebas Técnicas**:
    - Prueba de Vulnerabilidad: Se escanea la aplicación web con OWASP ZAP. Se encuentra una vulnerabilidad de Inyección SQL en el campo de búsqueda de pacientes.
    - Prueba de Penetración (Conceptual): El auditor demuestra que, explotando la SQLi, podría extraer la base de datos completa de pacientes.
4. **Análisis de Riesgos**:
    - Hallazgo 1 (Alto): Vulnerabilidad SQLi -> Riesgo de pérdida masiva de datos confidenciales (Confidencialidad).
    - Hallazgo 2 (Medio): Falta de trazabilidad en logs -> Riesgo de no poder auditar accesos indebidos internos (No-repudio).
5. **Resultado/Informe**: El auditor emite un informe indicando, no conforme, recomienda la corrección inmediata del código (parche de seguridad) y la implementación de un SIEM para centralizar y proteger los logs de acceso a datos sensibles.

ASIGNACION 2: pts

1. Investigue las metodologías y fases para realizar “auditoria” mediante COSO.

Fase de la Auditoría	Descripción y Metodología	Actividades Clave
1. Planificación y Evaluación de Riesgos	Fase para planificar la auditoría y realizar una evaluación inicial de riesgos del área a revisar, permitiendo al auditor enfocarse en los riesgos críticos (operativos, financieros, regulatorios y reputacionales) .	Solicitar información preliminar (financiera, organigrama, políticas), realizar entrevistas y walkthroughs (recorridos de procesos) para entender el flujo de operaciones, desarrollar el programa de trabajo y definir el alcance y objetivos de la auditoría .
2. Trabajo de Campo	Ejecución del programa de trabajo para determinar la adecuación del sistema de control interno y si funciona según lo previsto. Los controles se miden contra políticas, regulaciones y principios contables .	Realizar entrevistas a profundidad, análisis de datos, pruebas de controles y pruebas sustantivas de transacciones. Las deficiencias encontradas se documentan y se discuten preliminarmente con el personal responsable .
3. Elaboración del Informe	Documentar formalmente los hallazgos de la auditoría utilizando un enfoque estructurado. El informe se discute con el auditado antes de su emisión final para asegurar que no haya sorpresas y que se acuerden los hechos .	Redactar hallazgos siguiendo las "5 C's": Condición (lo que es), Criterio (lo que debería ser), Causa (origen de la desviación), Consecuencia (efecto adverso) y Recomendación (acciones para mitigar el riesgo) .
4. Seguimiento (Plan de Acción)	Procedimiento para asegurar que la gerencia implemente las recomendaciones acordadas para fortalecer los controles y mitigar los riesgos identificados. Auditoría Interna monitorea el progreso de los planes de acción .	Revisión periódica de la evidencia que soporta el cierre de las acciones correctivas. En caso de retrasos, se aplican procedimientos de escalamiento para asegurar su cumplimiento .

2. Prepare una guía, manual o formato para realizar “auditoria” según COSO.

MATRIZ DE EVALUACIÓN DE CONTROL INTERNO (COSO 2013)

Instrucciones de uso:

1. Para cada principio COSO, realice las Pruebas de Cumplimiento sugeridas.
2. Asigne una calificación basada en la evidencia recolectada.
3. Documente la Referencia del papel de trabajo donde guardó la evidencia.

Calificación:

- **E (Efectivo):** El control existe, está formalizado y opera consistentemente.
- **N/I (Necesita Mejora):** El control existe pero opera de manera informal, manual o con excepciones frecuentes.
- **D (Deficiente):** El control no existe o no opera.

Componente COSO	Principio	Prueba de Auditoría (¿Qué hacer?)	Calificación	Ref. P/T
1. Entorno de Control	**P1:** Demuestra compromiso con la integridad y valores éticos.	Revisar Código de Conducta firmado por empleados. Verificar sanciones por violaciones éticas. Entrevistar sobre el "Tono desde la Alta Dirección".		
	P2: Ejerce responsabilidad de supervisión.	Revisar Minutas del Comité de Auditoría o Junta Directiva. Verificar si se discuten riesgos financieros clave.		
	P3: Establece estructura, autoridad y responsabilidad.	Solicitar Organigrama actualizado y Descripciones de Puesto (con segregación de funciones).		

Componente COSO	Principio	Prueba de Auditoría (¿Qué hacer?)	Calificación	Ref. P/T
	P4: Demuestra compromiso con la competencia.	Revisar Evaluaciones de Desempeño anuales del personal clave del área auditada. Verificar planes de capacitación.		
	P5: Hace cumplir la rendición de cuentas.	Verificar indicadores de gestión (KPIs) del área. ¿Se mide el desempeño del control interno?		
2. Evaluación de Riesgos	**P6:** Especifica objetivos relevantes.	Solicitar Mapa Estratégico o Plan Operativo Anual del área auditada. ¿Los objetivos están alineados con la misión?		
	P7: Identifica y analiza los riesgos.	Solicitar Matriz de Riesgos del área. Verificar si incluye riesgo de Fraude y riesgo de Tecnología (IT) .		
	P8: Evalúa el riesgo de fraude.	Revisar segregación de funciones en sistemas (Ej: ¿Quien paga es quien registra?). Indagar sobre incentivos de ventas o presupuestos agresivos.		

Componente COSO	Principio	Prueba de Auditoría (¿Qué hacer?)	Calificación	Ref. P/T
	P9: Identifica y analiza cambios significativos.	Indagar sobre cambios recientes en sistemas informáticos, nueva regulación o rotación de personal clave.		
3. Actividades de Control	**P10:** Selecciona y desarrolla actividades de control.	Walkthrough (Recorrido): Seguir una transacción de inicio a fin. Identificar controles manuales y automáticos.		
	P11: Selecciona y desarrolla controles generales de TI.	Revisar políticas de contraseñas, altas/bajas de usuarios y backups.		
	P12: Despliega políticas y procedimientos.	Prueba de Atributos: Tomar muestra de 25 transacciones. Verificar si el 100% tiene la firma de autorización requerida por política.		
4. Información y Comunicación	**P13:** Genera y utiliza información relevante.	Evaluar calidad de reportes gerenciales. ¿La información llega completa, exacta y a tiempo para tomar decisiones?		

Componente COSO	Principio	Prueba de Auditoría (¿Qué hacer?)	Calificación	Ref. P/T
	P14: Comunica internamente.	Verificar si existe un Canal de Denuncias anónimo y si el personal sabe usarlo. Revisar difusión de nuevas políticas.		
	P15: Comunica externamente.	Revisar gestión de reclamos de clientes o proveedores. ¿Hay un proceso formal para recibir y atender quejas externas?		
5. Monitoreo	**P16:** Realiza evaluaciones continuas y/o separadas.	Revisar Conciliaciones Bancarias de los últimos 3 meses. ¿Están firmadas y revisadas por un supervisor?		
	P17: Evalúa y comunica deficiencias.	Prueba de Seguimiento: Revisar el estado de las observaciones de la auditoría anterior. ¿Se cerraron o están vencidas?		

3. Investigue las metodologías y fases para realizar auditoria mediante COBIT 5 o superior.

Metodología Principal: COBIT 5 for Assurance

La base metodológica para auditar con COBIT 5 es la guía oficial de ISACA, COBIT 5 for Assurance . Esta metodología no solo verifica la existencia de controles, sino que evalúa la capacidad de los procesos de TI para lograr los objetivos de negocio. La auditoría con COBIT se centra en evaluar los siete habilitadores (enablers) corporativos:

1. Principios, Políticas y Marcos de Referencia
2. Procesos (Modelo de Referencia)
3. Estructuras Organizacionales
4. Cultura, Ética y Comportamiento
5. Información
6. Servicios, Infraestructura y Aplicaciones
7. Personas, Habilidades y Competencias

Fases Estándar de una Auditoría con COBIT 5
La implementación de una auditoría basada en COBIT sigue típicamente un ciclo de vida estructurado en cuatro fases principales, según lo validado en la práctica profesional y académica :

Fase	Descripción y Actividades Clave
1. Planificación (Audit Plan)	Definir el alcance y los objetivos del negocio que soportan la auditoría. Identificar los dominios y procesos de COBIT relevantes (ej. APO, BAI, DSS, MEA). Realizar una evaluación preliminar de riesgos para priorizar recursos .
2. Preparación (Preparation)	Establecer los criterios de evaluación (alineados a COBIT o ISO/IEC 15504). Seleccionar los procesos específicos a evaluar y definir el nivel de capacidad objetivo esperado por la organización (Nivel 0 al 5) .
3. Ejecución (Implementation)	Recopilar evidencia (documentación, entrevistas, observación directa) para evaluar los atributos del proceso. Determinar el nivel de capacidad actual (ej. Nivel 2 "Proceso Gestionado" o Nivel 3 "Proceso Establecido"). Documentar hallazgos y brechas (gaps) .
4. Reporte (Reporting)	Comunicar resultados: Nivel de capacidad alcanzado vs. esperado. Presentar hallazgos y recomendaciones correctivas. Establecer un proceso de seguimiento (*Audit Follow-up*) para verificar la implementación de acciones acordadas .

El Proceso de Seguimiento

Un componente crítico en COBIT es la fase de Seguimiento de Recomendaciones, que asegura que los riesgos identificados sean mitigados. COBIT recomienda mantener un Registro de Hallazgos de Aseguramiento que rastree el estado del ciclo de vida de cada recomendación: Pendiente, En Progreso, Implementado (Pendiente de verificación) o Cerrado .

Medición de la Capacidad (Niveles de Madurez)
La auditoría con COBIT utiliza una escala de evaluación de capacidad basada en la norma ISO/IEC 15504 (parte del Programa de Evaluación de COBIT). Es crucial que el auditor verifique no solo la existencia del proceso (Nivel 1), sino también su gestión y documentación (Niveles 2 y 3) :

- **Nivel 1 (Realizado):** El proceso se ejecuta y logra su propósito, pero de manera informal o reactiva.
- **Nivel 2 (Gestionado):** El proceso se planifica, monitorea y ajusta; los productos de trabajo están controlados.
- **Nivel 3 (Establecido):** El proceso se ejecuta usando un proceso definido y estándar en toda la organización .

En la práctica, muchas organizaciones se encuentran en Nivel 2 o 3, lo que indica un proceso gestionado pero que aún requiere estandarización o mejora continua para alcanzar niveles de predictibilidad (Nivel 4) u optimización (Nivel 5) .

4. Prepare una guía, manual o formato para realizar auditoria mediante COBIT 5 o superior.

DATOS GENERALES Y ALCANCE

Campo	Descripción
Nombre del Proyecto de Auditoría	Auditoría de Procesos de TI Basada en COBIT 5
Alcance del Negocio	Proceso de Gestión de Cambios (BAI06) en el ERP Financiero.
Dominio COBIT Evaluado	☐ Evaluar, Orientar y Supervisar (EDM) ☐ Alinear, Planificar y Organizar (APO) ☐ Construir, Adquirir e Implementar (BAI) ☐ Entregar, Dar Servicio y Soporte (DSS) ☐ Supervisar, Evaluar y Valorar (MEA)
Proceso Específico	*Código y Nombre: BAI06 - Gestionar los Cambios*

CRITERIOS DE EVALUACIÓN

Instrucciones: Califique la evidencia observada usando la escala ISO/IEC 15504 (0-5) utilizada en COBIT 5.

Nivel	Nombre	Descripción para el Auditor
0	Incompleto	El proceso no está implementado o falla en su propósito.
1	Realizado	El proceso se ejecuta, pero es Ad-hoc (cada quien lo hace a su manera).
2	Gestionado	Objetivo mínimo aceptable. Hay planificación, responsables y productos de trabajo definidos.
3	Establecido	Existe un Procedimiento Estándar documentado que se sigue en toda la organización.
4	Predecible	El proceso se mide con métricas cuantitativas y es estable.
5	Optimizado	El proceso se mejora continuamente de forma proactiva.

MATRIZ DE EJECUCIÓN DE PRUEBAS

Esta es la herramienta central de trabajo de campo.

ID Proceso COBIT	Práctica de Gestión / Actividad Clave	Atributo Evaluado (PA)	Evidencia Requerida / Pregunta de Auditoría	Calificación Observada (0-5)	Brecha / Hallazgo
BAI06.01	Evaluar, priorizar y autorizar solicitudes de cambio.	PA 2.1 (Gestión)	¿Existe un Comité de Control de Cambios (CAB) formal con actas de reunión?	2	Existe el comité pero no se levantan actas formales de aprobación. (Brecha: Falta control de producto de trabajo).
BAI06.03	Autorizar y planificar cambios de emergencia.	PA 3.1 (Definición)	¿Existe un Procedimiento Documentado específico para Cambios de Emergencia distinto al estándar?	1	No existe procedimiento. Se maneja por correo electrónico informal. Riesgo Alto.
DSS05.02	Gestionar la seguridad de la red y conectividad.	PA 1.1 (Rendimiento)	¿Se realiza revisión periódica de reglas de Firewall?	3	Evidencia de revisiones trimestrales en herramienta de gestión.

ANÁLISIS DE HABILITADORES ADICIONALES

COBIT 5 establece que un proceso no funciona solo. El auditor debe revisar estos 6 puntos complementarios al proceso.

Habilitador	Pregunta Clave de Auditoría	Estado
Principios/Políticas	¿Está el proceso alineado con una Política de Gestión de TI aprobada por la Alta Dirección?	☐ Sí ☐ No
Información	¿La información generada por el proceso es Íntegra, Confiable y Oportuna?	☐ Sí ☐ No
Estructura Organizacional	¿Están definidos los Roles y Responsabilidades (RACI) para este proceso?	☐ Sí ☐ No
Personas/Habilidades	¿Ha recibido el personal Capacitación formal en COBIT o en este proceso específico?	☐ Sí ☐ No